

Créé par le Centre d'Excellence Cyberdéfense Aérospatiale (CEC)

Documentation

WAC (Windows Artefacts Collector)

Logiciel de prélèvement d'artefacts Windows
pour l'investigation numérique



ARTEFACTS
SYSTÈME



FICHIERS
UTILISATEUR



PREUVES
NUMÉRIQUES

UN OUTIL AU SERVICE
DE L'INVESTIGATION
NUMÉRIQUE

WAC — Windows Artefacts Collector

[Documentation utilisateur](#)

Version du logiciel 1.3.1

Édition du document septembre 2026

Éditeur Centre d'Excellence Cyberdéfense Aérospatiale (CEC)
École de l'air et de l'espace, base aérienne 701, Salon-de-Provence

Ce document décrit l'emploi de WAC : préparation, exécution d'une collecte, lecture et vérification des résultats, et traces laissées sur la machine examinée. Les mesures citées ont été relevées sur une machine virtuelle Windows 11 de test; elles donnent des ordres de grandeur, pas des engagements.

Table des matières

1	Présentation	2
1.1	À quoi sert WAC	2
1.2	Le principe directeur : une empreinte minimale	2
1.3	Ce que WAC ne fait pas	2
2	Principes de fonctionnement	4
2.1	Lecture directe du disque	4
2.2	Consigne et travail	4
2.3	Ruches du registre et journaux de transaction	5
2.4	L'extraction en deux temps	5
2.5	Ce qui reste lu « à chaud »	5
3	Préparer une collecte	6
3.1	Prérequis	6
3.2	Le support de collecte	6
3.3	Avant d'intervenir	7
4	Lancer une collecte	8
4.1	Ligne de commande	8
4.2	Fichier de configuration : wac.yml	8
4.3	Options	9
4.4	Exemples	10
4.5	L'option --binary	10
4.6	Déroulement à l'écran	12
4.7	Durée	13
5	Collecter ici, convertir ailleurs	14
5.1	Pourquoi séparer	14
5.2	Quel mode choisir	15
5.3	Les deux commandes	15
5.4	Ce que prend --collect	15

5.5	Ce que fait --convert	16
5.6	Limites	17
6	Les résultats	18
6.1	Arborescence	18
6.2	Le manifeste de consigne	18
6.2.1	En-tête	18
6.2.2	Chaque pièce	18
6.3	Vérifier l'intégrité d'une collecte	20
6.3.1	Le sceau	20
6.3.2	Chaque pièce	20
6.4	Le journal d'investigation	21
6.5	Les fichiers d'artefacts	21
6.5.1	Système et comptes	22
6.5.2	Exécution de programmes	22
6.5.3	Fichiers et navigation	23
6.5.4	Périphériques	23
6.5.5	Journaux d'événements (--events)	23
7	Lire les données	25
7.1	Horodatages	25
7.2	Noms des comptes	25
7.3	Noms des GUID	25
7.4	Un champ absent n'est pas un champ vide	26
7.5	Artefact non collecté	26
7.6	Données non décodées	26
7.7	Chemins	26
8	Traces laissées sur la machine examinée	27
8.1	Ce que WAC fait encore	27
8.2	Ce que WAC ne fait plus	28
8.3	Ce qu'aucun outil ne peut éviter	28
9	Limites connues	29
10	Dépannage	30

A	Glossaire	31
----------	------------------	-----------

Présentation

1.1 À quoi sert WAC

WAC prélève, sur un poste Windows en fonctionnement, les artefacts utiles à une investigation numérique : base de registre, journaux d'événements, fichiers Prefetch, raccourcis et listes de sauts, tâches planifiées, services, comptes, processus et sessions. Il les restitue sous forme de fichiers **JSON**, prêts à être analysés ou versés dans une chaîne de traitement.

Il s'exécute depuis une clé USB, sans installation, et écrit tout ce qu'il produit sur cette clé.

1.2 Le principe directeur : une empreinte minimale

Examiner une machine la modifie. Chaque outil lancé laisse des traces : fichiers ouverts dont la date de dernier accès change, services sollicités qui écrivent dans les journaux, clés de registre lues par l'API. Ces traces se mêlent à celles que l'on cherche.

WAC est conçu pour que ce qu'il laisse derrière lui soit aussi proche de rien que la tâche le permet, et pour que **ce qu'il ne peut pas éviter soit écrit**. Concrètement :

- le disque est lu **directement**, en lecture seule, sans ouvrir aucun fichier par le système : aucune date d'accès n'est modifiée ;
- aucune clé du registre de la machine n'est ouverte : les ruches sont copiées, puis lues sur la copie ;
- aucun cliché instantané (VSS), aucun appel COM ou WMI, aucun service de journalisation n'est sollicité ;
- rien n'est écrit sur le disque examiné ;
- chaque opération est consignée, avec la trace qu'elle est censée laisser, dans `investigation.json`.

1.3 Ce que WAC ne fait pas

- WAC **n'analyse pas** : il prélève et met en forme. L'interprétation revient à l'analyste.
- Il ne réalise pas d'image complète du disque : il extrait les fichiers porteurs d'artefacts.
- Il ne capture pas la mémoire vive. Les seules données volatiles relevées sont la liste des

processus, les sessions ouvertes et l'état des services.

Principes de fonctionnement

2.1 Lecture directe du disque

WAC ouvre le volume (\\.\C:) en lecture seule, parcourt lui-même la table des fichiers NTFS (\$MFT) et en extrait le contenu des fichiers utiles. Le système ne voit aucune ouverture de fichier : ni date d'accès mise à jour, ni parcours de répertoire, ni verrou.

Cette lecture prend en charge les particularités de NTFS que Windows masque d'ordinaire :

Compression NTFS

Windows 11 compresse notamment le dossier des journaux d'événements. WAC les décompresse lui-même.

Compact OS (WOF)

Les binaires système de Windows 10 et 11 sont stockés compressés dans un flux caché ; vus par l'API, ils paraissent ordinaires. WAC les décompresse (variantes XPRESS).

Attributs éclatés

Un fichier très fragmenté voit ses informations réparties sur plusieurs enregistrements ; WAC les réunit.

Fichiers préalloués

Au-delà de la longueur de données valides, NTFS rend des zéros, même si le disque contient encore les restes d'anciens fichiers. WAC fait de même : le contenu extrait est celui que verrait toute acquisition ordinaire, et son empreinte aussi.

2.2 Consigne et travail

Une pièce à conviction numérique ne s'examine jamais sur elle-même : on en fait une copie, on la scelle, et l'on travaille sur une seconde copie. Si l'analyse abîme quelque chose, la copie scellée demeure et l'opération peut être refaite.

WAC applique cette procédure à **tous** les fichiers extraits, y compris ceux qu'il ne modifie pas :

exhibits/

les copies brutes, telles que lues sur le volume. Ce répertoire n'est plus jamais rouvert en écriture après l'extraction. Il contient le manifeste qui identifie chaque pièce, et le sceau du manifeste.

working/

les copies de travail, recopiées depuis la consigne et vérifiées par empreinte. C'est ici que

sont faites les seules modifications (rejeu des journaux de transaction des ruches), et c'est ici que lisent tous les collecteurs.

À retenir

Chaque fichier extrait est donc écrit **deux fois** sur le support de collecte. Prévoyez la place correspondante (voir section 3.2).

2.3 Ruches du registre et journaux de transaction

Une ruche copiée sur une machine en fonctionnement ne contient pas les dernières modifications : elles sont encore dans ses journaux de transaction (.LOG1, .LOG2). WAC extrait ces journaux et les **rejoue sur la copie de travail**, pour que l'analyse porte sur l'état réel de la machine.

Tout ce que WAC écrit sur une copie est réversible : avant le rejeu, le contenu d'origine de chaque page remplacée est sauvegardé dans un journal d'annulation (<ruche>.undo). La copie brute, elle, reste intacte dans la consigne.

2.4 L'extraction en deux temps

L'emplacement des ruches de chaque utilisateur est inscrit dans la ruche SOFTWARE. WAC extrait donc d'abord les ruches de la machine (SYSTEM, SOFTWARE, SAM, Amcache), lit la liste des profils dans la copie de SOFTWARE, puis extrait les ruches de chaque profil (ntuser.dat, usrClass.dat).

Rien n'est supposé sur C : le lecteur système est détecté, et un profil situé sur un autre disque (par exemple D:\Users\...) est lu sur son propre volume.

2.5 Ce qui reste lu « à chaud »

Quelques informations décrivent l'instant même de la collecte et ne figurent dans aucun fichier. Elles sont lues en direct, en une seule requête chacune, et enregistrées telles que lues dans la consigne (exhibits\live), où la conversion les relit :

- la liste des **processus** en cours (instantané du noyau);
- les **sessions** ouvertes;
- l'**état courant des services** (la configuration, elle, est lue dans la ruche copiée);
- l'**horloge** et l'heure de démarrage;
- les **réglages** de la machine en marche : lecteur système, page de code, fuseau horaire, volumes et leurs numéros de série.

Préparer une collecte

3.1 Prérequis

- Windows 10 ou ultérieur, 64 bits. WAC le vérifie au lancement.
- Des **droits d'administrateur** : la lecture directe d'un volume les exige. WAC le vérifie également.
- Des volumes **NTFS**. Un fichier situé sur un autre système de fichiers (CD-ROM, clé FAT) ne peut pas être lu directement ; il est signalé comme non lu, jamais ouvert autrement.

3.2 Le support de collecte

WAC s'exécute depuis le support de collecte (en général une clé USB) et y écrit tous ses résultats. Choisissez un support **vide**, de préférence en USB 3 : l'écriture est le poste le plus coûteux d'une collecte.

La place nécessaire dépend des options. Ordres de grandeur mesurés sur une installation Windows 11 ordinaire, pour les copies brutes seules :

Contenu	Volume des copies brutes
Ruches, Prefetch, raccourcis, listes de sauts (toujours)	environ 200 à 350 Mo
Journaux d'événements et leurs binaires de messages (--events)	environ 250 Mo
Binaires cités non authentifiés Microsoft (--binary)	quelques centaines de Mo

Chaque copie étant écrite deux fois (consigne et travail), **doublez ces chiffres**. Une collecte complète (--events --binary) occupe ainsi de l'ordre de 1,5 à 2 Go sur une installation ordinaire.

WAC vérifie l'emplacement **avant la toute première écriture** et refuse de démarrer :

- si le répertoire de travail contient déjà des fichiers — une collecte antérieure serait analysée à la place de celle-ci ;
- si la place libre est manifestement insuffisante.

Si la place vient à manquer en cours de prélèvement des binaires, ceux-ci sont hachés sans être copiés, et le journal d'investigation l'indique.

3.3 Avant d'intervenir

- Utilisez un **dossier de sortie neuf** pour chaque machine (option --output).
- Notez l'heure de l'intervention et l'identité de l'opérateur : WAC les consigne aussi, mais une trace indépendante est utile.
- Gardez à l'esprit que brancher la clé et lancer WAC laissent des traces inévitables (chapitre 8) : elles sont connues et documentées, afin de ne pas être confondues avec l'activité étudiée.

Lancer une collecte

4.1 Ligne de commande

Ouvrez une invite de commandes **en tant qu'administrateur**, placez-vous sur le support de collecte, puis lancez :

```
WAC.exe [--collect | --convert=dossier] [--events] [--binary | --binary-all]
        [--threads=N] [--dump]
        [--output=dossier] [--loglevel=N] [--debug]
WAC.exe --update-trust[=dossier]
```

Toutes les options sont facultatives et désactivées par défaut.

4.2 Fichier de configuration : wac.yml

La dernière version compilée se trouve dans WAC/bin du dépôt : WAC.exe, le wac.yml de référence et SHA256SUMS pour les vérifier. Copier WAC.exe et wac.yml sur la clé de collecte suffit.

Plutôt que de retaper les options à chaque collecte, la procédure s'écrit une fois dans wac.yml, à côté de WAC.exe : WAC l'applique d'abord, et une option donnée en ligne de commande la surcharge. --write-config écrit le fichier de référence, commenté — la procédure recommandée : collecte seule, binaires non vérifiés prélevés, journaux d'événements compris.

```
convert: false           # true : collecte et conversion ici ; false : collecte seule
binary: unverified       # none | unverified | all
threads: 0               # fils d'analyse des binaires, 0 : automatique
output: output
log_level: 0
dump: false
artefacts:               # un interrupteur par artefact ; toutes les ruches = registry
  registry: true
  events: true
  scheduled_tasks: true
  services: true
  processes: true
  sessions: true
  prefetch: true
  jump_lists: true
  recent_documents: true
```

- **Strict** : une clé inconnue, une valeur hors de celles admises (`true/false` seulement, pas `yes`), une clé en double, une liste : la collecte est refusée avant de commencer, avec la ligne fautive. Une clé absente garde sa valeur par défaut.
- **Consigné** : chemin, SHA-256 et contenu du fichier vont dans `investigation.json` (`Tool.Configuration`) — la procédure appliquée fait partie de la preuve.
- Un artefact désactivé n'est pas lu du tout, et son fichier JSON le dit (`CollectionStatus NotRequested`, avec la clé) : jamais confondu avec un échec ou une absence de traces.
- `--config=fichier` lit un autre fichier ; `--full` collecte et convertit ici bien que le fichier dise `convert: false`.
- Sans `wac.yml`, WAC se comporte comme avant : exécution complète, options telles que données.

4.3 Options

Option	Effet
<code>--collect</code>	Collecte seule, sur la machine examinée : relevés en direct et extraction brute dans la consigne scellée, rien n'est converti. Voir chapitre 5.
<code>--convert=dossier</code>	Conversion seule, sur un poste d'analyse, de la collecte faite avec <code>--collect</code> dans ce dossier, après vérification du sceau et de chaque empreinte. Voir chapitre 5.
<code>--events</code>	Extrait et analyse les journaux d'événements (<code>.evtx</code>), et reconstitue le message lisible de chaque événement à partir des ressources de son fournisseur. Ajoute environ 250 Mo de copies.
<code>--binary</code>	Calcule les empreintes (MD5, SHA-1, SHA-256) de chaque fichier cité par un artefact, par lecture directe du disque. Les exécutables, bibliothèques, pilotes et scripts cités sont en outre prélevés dans la consigne. Voir section 4.5.
<code>--binary-all</code>	Comme <code>--binary</code> , mais tout exécutable est prélevé, authentifié ou non ; la signature est tout de même vérifiée, et le manifeste dit pour chacun si elle est valide. Pour les dossiers où le contenu même doit figurer dans la consigne.
<code>--threads=N</code>	Nombre de fils qui analysent les exécutables de <code>--collect</code> <code>--binary</code> (PE, Authenticode, catalogues, empreintes). Par défaut, le nombre de fils du processeur moins un, la lecture du disque gardant le sien. Le résultat n'en dépend pas : le manifeste est le même.

Option	Effet
--update-trust [=dossier]	Sur le poste d'analyse, avant la collecte, et seule : télécharge chez Microsoft la liste des racines de confiance (authroot.stl), celle des certificats désapprouvés (disallowedcert.stl) et chacune des racines, vérifie leurs signatures et leurs empreintes, ainsi que les listes de pilotes vulnérables de Microsoft et de LOLDrivers (non signées : authentifiées par HTTPS seul) et les listes de révocation (CRL) des autorités de signature de code que recense la CCADB, de celles propres à Microsoft et de celles qu'une collecte précédente a trouvées manquantes (wanted-crls.txt), et les écrit dans dossier (par défaut trust, à côté de WAC.exe), à emporter sur la clé avec WAC.exe. Seul mode qui utilise le réseau : la bibliothèque réseau n'est chargée que là. Refusée avec toute autre option.
--dump	Ajoute la valeur hexadécimale brute des éléments de shellbags et de raccourcis .lnk, pour un décodage ultérieur.
--output=dossier	Dossier de sortie, relatif au répertoire courant. Par défaut : output.
--loglevel=N	Active un journal texte détaillé, dans le répertoire courant, nommé d'après le programme lancé (WAC.exe.log pour WAC.exe) : 0 aucun, 1 par type d'artefact, 2 par artefact, 3 par sous-fonction (mise au point).
--debug	Affiche sur la sortie d'erreur la trace du lecteur NTFS (résolution des chemins, blocs d'index, séquences de grappes). Réservé au diagnostic.
--help, /?	Affiche l'aide.

4.4 Exemples

Collecte standard :

```
E:\> WAC.exe --output=poste-comptable-01
```

Collecte complète, avec journaux, binaires et journal détaillé :

```
E:\> WAC.exe --events --binary --output=poste-comptable-01 --loglevel=2
```

4.5 L'option --binary

Une empreinte suffit pour interroger une base publique (VirusTotal, par exemple) **sans lui envoyer le fichier**. Mais elle ne dit rien d'un binaire que personne ne connaît — précisément celui qui intéresse l'enquête — et un binaire non prélevé peut avoir disparu quand une

détection survient. C'est pourquoi --binary copie aussi les charges potentielles :

- **prélevés** : exe, dll, sys, ocx, cpl, scr, drv, efi, com, msi et les scripts ps1, psm1, bat, cmd, vbs, vbe, js, jse, wsf, wsh, hta;
- **prélevés aussi** : les documents Office **capables de porter des macros**, vecteur d'intrusion aussi courant qu'un exécutable — formats binaires anciens (doc, xls, ppt, pps, dot, xlt, pot), formats « m » (docm, dotm, xlsx, xlsm, pptm, potm, ppsm), xlsb, compléments (xla, xlam, xll, wll, ppa, ppam), Publisher (pub), Visio (vsd, vsdm, vstm, vssm) et Access (mdb, accdb, accde). Ils apparaissent dans les traces comme cibles de raccourcis ou de listes de sauts, ou parmi les fichiers chargés par Word ou Excel dans leur Prefetch;
- **seulement hachés** : les autres documents et fichiers de données, y compris docx, xlsx et pptx, qui ne peuvent pas contenir de macros. Les copier ferait de la collecte une copie des fichiers de l'utilisateur.

Les fichiers cités proviennent des processus, services (binaire et DLL), tâches planifiées, fichiers chargés par les programmes (Prefetch), Shimcache, Amcache et cibles de raccourcis et de listes de sauts. Chaque fichier n'est lu qu'une fois, quel que soit le nombre d'artefacts qui le citent, et **un même contenu n'est stocké qu'une fois** : les autres chemins figurent au manifeste comme pièces partageant ce contenu (SharedExhibit).

Binaires Microsoft authentiques : hachés, non prélevés

La plupart des binaires cités sont des composants de Windows, identiques sur toute machine de la même version. Leur origine se prouve sur la machine elle-même, sans liste à embarquer : les **catalogues** de Windows, signés par Microsoft, listent l'empreinte de chaque fichier du système. WAC lit ceux de System32\CatRoot, ceux des composants (WinSxS\Catalogs) et ceux des paquets de maintenance (servicing\Packages), plus de 13 000 sur Windows 11. Les binaires signés individuellement (Edge, OneDrive, Office, .NET) portent une **signature intégrée**. Un binaire authentifié ainsi est haché sans être prélevé; tous les autres sont prélevés — y compris un binaire système remplacé par un attaquant, dont l'empreinte ne correspond plus.

Cette vérification ne laisse **aucune trace** : catalogues et binaires sont lus directement sur le disque, et la vérification cryptographique est faite en mémoire par WAC, jusqu'à des certificats racines Microsoft embarqués dans l'exécutable. Aucun service n'est sollicité, le magasin de certificats de la machine n'est pas consulté, et la révocation n'est pas contrôlée en ligne.

Seuls les signataires Microsoft pour son propre code sont acceptés (« Microsoft Windows », « Microsoft Corporation », « Microsoft Windows Publisher » et « .NET »). Les pilotes **tiers** certifiés par Microsoft (signataires « Hardware Compatibility Publisher » et « Early Launch Anti-malware Publisher ») restent prélevés : un pilote vulnérable mais signé est un moyen d'attaque classique.

Applications du Store : vérifiées par leur paquet

Les fichiers d'une application du Store ne sont pas signés un à un : c'est leur **paquet** qui l'est. Son dossier contient la signature (AppxSignature.p7x) et la carte des blocs (AppxBlockMap.xml), qui donne le SHA-256 de chaque bloc de 64 Kio de chaque fichier. WAC vérifie la signature, qui doit remonter à une racine Microsoft (le Store signe les paquets qu'il distribue), vérifie qu'elle garantit bien cette carte, puis compare chaque bloc lu à la carte. Un fichier conforme est haché sans être prélevé; un fichier modifié, ou ajouté au dossier après l'installation, est prélevé, de même que tout fichier d'un paquet signé hors de la chaîne Microsoft.

Les catalogues, signatures et cartes de blocs qui ont justifié un non-prélèvement sont consignés, pour qu'un tiers puisse refaire la vérification. Dans les fichiers d'artefacts, le champ Signature (ou ServiceDllSignature, SignatureTarget...) indique l'authentification retenue, par exemple « Microsoft (catalog C:\Windows\...\cat) », « Microsoft (embedded signature) » OU « Package (package C:\Program Files\WindowsApps\...) ».

Les **scripts** sont authentifiés de la même façon : par les catalogues de Windows, et, pour PowerShell (ps1, psml, psd1, ps1xml...), par leur bloc de signature intégré (# SIG # Begin signature block). Un script Windows Script Host (vbs, js, wsf) signé seulement dans son texte, et non par un catalogue, reste prélevé.

Sur la machine de test, cette vérification ramène le prélèvement de 2 131 binaires (3,3 Go) à 92 (335 Mo), sans allonger la collecte; les scripts encore prélevés sont ceux qui ne sont pas signés.

La lecture étant directe, prélever ne laisse aucune trace de plus que hacher : seulement de la place sur le support.

4.6 Déroulement à l'écran

WAC affiche chaque étape, suivie de OK ou d'un message d'erreur. Une étape en échec n'interrompt pas la collecte : tout ce qui est accessible est recueilli, et ce qui manque est consigné.

```
[PREREQUISITE VERIFICATION]
- Check OS >= Windows 10 : OK
- Check administrator rights : OK
- Checking the collection medium : OK
[SEARCHING FOR ARTIFACTS IN WINDOWS API]
- Extraction of SESSIONS: OK
- Extraction of PROCESS: OK
[RAW EXTRACTION]
- Extracting system hives (raw NTFS) : OK
- loading the HKLM\SYSTEM key : OK
- loading the HKLM\SOFTWARE key : OK
- Listing USER PROFILES (SOFTWARE hive) : OK
- Extracting user hives (raw NTFS) : OK
- Extracting file artefacts (raw NTFS) : OK
[SEARCHING FOR ARTIFACTS IN THE REGISTRY]
```

```
- Extracting USERASSIST Registry Keys : OK
...
[SEARCHING FOR ARTIFACTS IN FILES]
- Extracting PREFETCHS : OK
...
[SEARCHING FOR ARTIFACTS IN EVENT LOGS]
- Extraction of EVENTS: OK
[EXHIBIT STORE]
- Copying collected binaries to the working directory : OK
- Sealing the exhibit store (manifest + SHA-256) : OK
[INVESTIGATION LOG]
- Writing investigation.json : OK
END, Time elapsed : 309 s
```

Le scellement de la consigne est la **dernière** opération sur celle-ci : toutes les pièces, y compris celles ajoutées pendant l'analyse des journaux, sont couvertes par le manifeste.

4.7 Durée

La durée dépend surtout du matériel (USB 2 ou 3, disque, processeur) et des options. Sur la machine virtuelle de test (disque NVMe) : environ 70 s avec `--events`, environ 310 s avec `--events` et `--binary`. Sur une clé USB, l'écriture domine.

Collecter ici, convertir ailleurs

5.1 Pourquoi séparer

Une exécution de WAC fait deux choses différentes :

1. **la collecte** : relever ce que seul un système en marche montre (processus, sessions, état des services, horloge), lire le disque directement, copier les preuves dans une consigne scellée. Elle a **besoin** de la machine examinée;
2. **la conversion** : décoder en JSON des milliers de fichiers copiés (ruches, journaux, Prefetch, raccourcis...). Elle n'a besoin que de la consigne, **pas** de la machine.

Sans option de mode, les deux se font sur la machine examinée. La conversion y ajoute un travail que rien n'impose : des minutes de traitement dans la mémoire de WAC, que Windows peut paginer dans `pagefile.sys`, sur le disque même qu'on examine; un processus présent plus longtemps, vu et journalisé par les protections de la machine; en cas de plantage, un rapport d'erreur Windows écrit sur la machine. Elle ne lit pourtant ni les fichiers ni le registre de la machine, seulement les copies du support de collecte, mais elle s'y exécute.

C'est précisément ce que les bonnes pratiques demandent d'éviter :

- **ISO/IEC 27037** traite de l'identification, de la collecte et de la préservation des preuves numériques, **ISO/IEC 27042** de leur analyse : deux étapes distinctes;
- **principe 1 de l'ACPO** : aucune action ne doit modifier les données de la machine examinée; toute opération qui s'y exécute doit être nécessaire;
- **principe 3 de l'ACPO** : un tiers indépendant doit pouvoir refaire le traitement et obtenir le même résultat.

Séparer les deux étapes apporte trois choses :

- **moins de traces** sur la machine examinée : seule la collecte s'y exécute;
- **des preuves vérifiées avant toute analyse** : --convert contrôle d'abord le sceau et le SHA-256 de chaque pièce, et refuse une collecte retouchée;
- **une analyse reproductible** : deux conversions d'une même collecte donnent des fichiers JSON identiques octet pour octet, et l'analyse peut être refaite plus tard, avec une version corrigée de WAC ou par un tiers, sans revenir sur la machine.

5.2 Quel mode choisir

- **Par défaut : --collect sur la machine, --convert sur le poste d'analyse.** C'est la procédure qui laisse le moins de traces sur la machine examinée, garde les preuves scellées et permet de refaire et de vérifier l'analyse.
- **Exécution complète** (sans option de mode) : à réserver aux cas particuliers, à signaler au rapport — un tri dont les résultats sont attendus sur place sans poste d'analyse, une machine à rendre en quelques minutes. Sa conversion ne lit que les copies du support de collecte, jamais les fichiers ni le registre de la machine, mais elle s'exécute sur celle-ci : des minutes de traitement en mémoire (que Windows peut paginer dans `pagefile.sys`), un processus plus long, un rapport d'erreur Windows en cas de plantage.
- **Portée de --binary** : en exécution complète, seuls les fichiers **cités par les artefacts** sont lus; un binaire du disque qu'aucun artefact ne cite n'est pas examiné. Avec `--collect`, ce sont **tous les exécutables de tous les volumes fixes NTFS**, cités ou non. La collecte seule dure plus longtemps pour cette raison (16 min 39 s contre 4 min 33 s sur la machine de test) : ce temps est de la lecture, qui n'écrit rien sur la machine.
- **--binary-all** : quand le contenu de chaque exécutable doit figurer dans la consigne (analyse de logiciel malveillant, demande des fichiers eux-mêmes), pour environ 20 Go.

5.3 Les deux commandes

Sur la machine examinée, en administrateur :

```
E:\> WAC.exe --collect --events --binary --output=poste-comptable-01
```

Sur le poste d'analyse, sans droits particuliers, avec les mêmes options `--events` et `--binary` que la collecte :

```
D:\> WAC.exe --convert=E:\poste-comptable-01 --events --binary
```

Les fichiers JSON sont écrits dans le dossier de la collecte, à côté de la consigne. `--convert` exclut `--collect` et `--output`.

5.4 Ce que prend --collect

La conversion ne pouvant plus rien demander à la machine, la collecte prend **tout ce qu'elle lira** :

- les **relevés en direct**, enregistrés tels que lus dans `exhibits\live` et scellés comme toute pièce : processus, sessions, état des services, horloge et démarrage, et les réglages de la machine (lecteur système, page de code, fuseau horaire, volumes et leurs numéros de série);

- les ruches et les fichiers d'artefacts, comme d'ordinaire;
- avec `--events`, les fichiers de ressources de **tous** les fournisseurs d'événements déclarés (binaire, fichier de paramètres, satellites `.mui`), car on ne sait qu'à la conversion lesquels seront utiles. Cela représente environ 650 Mo sur Windows 11;
- avec `--binary`, **tous** les exécutables, bibliothèques, pilotes, scripts et documents à macros de **tous les volumes fixes NTFS** — un profil sur D: compris —, lus directement et vérifiés en mémoire, comme en exécution complète (section 4.5) :
 - authentifié (catalogue, signature intégrée, paquet du Store), ou binaire tiers dont la signature tient face au jeu de confiance de la clé (`--update-trust` : chaîne vers une racine admise par Microsoft pour la signature de code, valide à la date de signature, non révoquée, pas un pilote vulnérable) : **non copié**; sans jeu de confiance utilisable, tout binaire tiers est copié, et le journal d'investigation le dit; le manifeste garde son chemin, ses empreintes Authenticode et le verdict (`ContentStored` à `false`);
 - non authentifié : **copié**, avec ses trois empreintes MD5, SHA-1, SHA-256, son empreinte Authenticode et la raison;
 - fichier différentiel de Windows (PA30/PA31, dossiers `r` et `f` de `WinSxS`) : ce n'est pas un exécutable; haché, non copié.

Un même contenu n'est stocké qu'une fois, et les autres noms d'un lien physique (`System32` et `WinSxS`) sont déclarés au manifeste comme le premier. Les volumes amovibles, dont le support de collecte, et les fichiers de mémoire (`pagefile.sys`, `swapfile.sys`, `hiberfil.sys`) sont exclus.

Attention

Avec `--binary`, la collecte lit tout le volume : sur la machine virtuelle de test (Windows 11 sans logiciel ajouté), 43 520 exécutables lus, dont 27 966 authentifiés et 12 700 fichiers différentiels non copiés, 2 507 copiés (676 Mo), en 16 minutes; la consigne entière, journaux d'événements compris, pèse 1,8 Go. Si la place vient à manquer, les fichiers restants sont hachés sans être copiés, et le manifeste l'indique.

Aucun fichier JSON d'artefact n'est écrit : le dossier ne contient que la consigne scellée, le répertoire de travail et `investigation.json`.

5.5 Ce que fait `--convert`

1. **Vérification**, avant toute lecture : le sceau doit porter l'empreinte réelle du manifeste, et chaque pièce son empreinte SHA-256. Une seule pièce altérée, et la conversion est **refusée**; `conversion.json` en donne la raison.
2. **Reconstruction du répertoire de travail** depuis la consigne : l'ancien est supprimé plutôt que cru, les copies sont vérifiées contre le manifeste et les ruches réparées, comme à la collecte. Les exécutables et les ressources des fournisseurs sont lus dans

la consigne même, sans copie.

3. **Conversion**, depuis les seules pièces : aucune lecture de la machine qui convertit, ni de son disque, ni de son registre, ni de son fuseau horaire.

La consigne n'est jamais modifiée et son sceau reste celui de la collecte. `investigation.json` reste le journal de la collecte; `conversion.json` est celui de la conversion (opérateur, poste, opérations). Deux conversions d'une même collecte donnent des fichiers JSON identiques, ce que le harnais de test vérifie à chaque cycle.

5.6 Limites

- Les **documents à macros** (`doc`, `docm`, `xls`, `xlsm`, `ppt...`, liste de la section 4.5) sont traités comme les exécutables : lus sur tous les volumes fixes et **prélevés**, sauf s'ils sont, octet pour octet, un fichier livré par Microsoft et listé dans un catalogue — ce qu'un document écrit ou modifié par quiconque ne peut pas être.
- Un fichier cité qui ne peut porter ni code ni macro (`docx`, `xlsx`, `pdf`, donnée) n'est pas prélevé : en conversion, il n'a donc **pas d'empreinte**, là où l'exécution complète la calcule sur le disque.
- Un exécutable authentifié n'est pas copié : à la conversion, il a son empreinte Authenticode et son verdict, mais pas de MD5, SHA-1 ni SHA-256 — ceux-ci ne sont calculés que pour ce qui est prélevé.
- Un exécutable situé sur un volume amovible n'est pas prélevé par `--collect --binary`.
- Les options `--events` et `--binary` de la conversion doivent être celles de la collecte : ce que la collecte n'a pas pris ne peut pas être converti.

Les résultats

6.1 Arborescence

```
<sortie>/
  exhibits/           copies brutes, jamais réécrites
    MANIFEST.json     identification de chaque pièce et de la collecte
    MANIFEST.sha256   empreinte du manifeste : son sceau
    Windows/...      les pièces, sous leur chemin d'origine
    Users/...
  working/           copies de travail (ruches rejouées)
  investigation.json  journal de la collecte
  *.json             les artefacts
```

Un fichier d'un autre volume que le volume système est rangé sous `_volume_D\...`; le JSON indique toujours le chemin d'origine, avec sa vraie lettre de lecteur.

6.2 Le manifeste de consigne

`exhibits/MANIFEST.json` identifie la collecte et chaque pièce.

6.2.1 En-tête

Tool

nom de l'outil, ligne de commande, date de compilation.

Host

nom de la machine, lecteur système, fuseau horaire du suspect (lu dans sa ruche SYSTEM) et de la machine de collecte.

Operator

compte ayant lancé la collecte, et s'il était élevé.

Custody

déclaration de procédure, début de l'extraction, heure d'écriture du manifeste, nombre de pièces et d'échecs, volume total, algorithmes d'empreinte, volumes lus (lettre, numéro de série, système de fichiers).

6.2.2 Chaque pièce

Champ	Signification
SourcePath	Chemin d'origine, avec lettre de lecteur.
ExhibitPath	Emplacement de la copie brute, relatif au dossier de sortie.
Method	Méthode de collecte (lecture directe NTFS, volume, motif).
Result	OK, ou le code et le message d'erreur. Les échecs figurent au manifeste : une pièce absente se lirait comme une pièce jamais cherchée.
MD5, SHA1, SHA256	Les trois empreintes, calculées pendant l'écriture : elles portent sur ce qui a été lu du volume.
Bytes	Taille extraite.
DeclaredBytes	Taille déclarée par NTFS, présente seulement si elle diffère de la taille extraite (extraction tronquée).
ValidDataBytes	Longueur de données valides d'un fichier préalloué (journaux d'événements) : au-delà, la pièce contient des zéros par définition.
SharedExhibit	true si le contenu, identique octet pour octet, est déjà stocké sous une autre pièce : ExhibitPath désigne celle-ci. La source reste une pièce à part entière, avec ses propres chemin, entrée \$MFT et horodatages.
MftEntry	Numéro d'enregistrement NTFS : identifie le fichier indépendamment de son nom.
Extracted(Utc)	Instant de l'extraction de cette pièce.
SourceCreated, SourceModified, SourceMftModified, SourceAccessed	Les quatre horodatages NTFS du fichier d'origine (\$STANDARD_INFORMATION), en UTC et en heure locale du suspect. Ce sont eux, et non les dates des copies, qui datent le fichier.
SourceFileName Created, Modified, MftModified, Accessed	Les quatre horodatages de l'attribut \$FILE_NAME du nom lu. NTFS les tient à part, et une modification des dates par programme ne les touche pas : un SourceCreated antérieur à SourceFileNameCreated est le signe classique de dates falsifiées après coup (<i>timestomping</i>).
ContentStored	false : binaire authentifié lu mais non copié (--collect --binary); il n'a pas de ExhibitPath.
AuthenticodeSHA1, AuthenticodeSHA256	Empreintes Authenticode d'un PE, celles que couvrent sa signature et les catalogues ; seules empreintes d'un binaire authentifié non copié.
SignatureVerified	Résultat de la vérification de signature d'un exécutable : true avec Signature (ce qui l'authentifie), false avec SignatureReason (pourquoi).

Champ	Signification
PeTimeStamp, PeSizeOfImage, SymbolServerKey	Version d'un PE et clé (nom/HORODATAGetaille/nom) sous laquelle le serveur de symboles de Microsoft la conserve : un binaire Microsoft authentique non copié peut en être retéléchargé, identique, et son empreinte vérifiée.

Pourquoi trois empreintes

Des collisions MD5 se fabriquent à volonté depuis 2008, et SHA-1 depuis 2017 : une empreinte seule ne tranche plus une contestation d'identité. Trois empreintes indépendantes, si.

6.3 Vérifier l'intégrité d'une collecte

6.3.1 Le sceau

Le manifeste ne peut pas contenir sa propre empreinte : elle est dans MANIFEST.sha256. Sous Linux :

```
$ cd sortie/consigne
$ sha256sum -c MANIFEST.sha256
MANIFEST.json: OK
```

6.3.2 Chaque pièce

Le script verifier-consigne.ps1, fourni avec cette documentation, vérifie le sceau puis le SHA-256 de chaque pièce :

```
PS> powershell -ExecutionPolicy Bypass -File verifier-consigne.ps1 -Sortie E:\output
Sceau conforme (DCFF53FAE709EC2E351FFFD02EC6EAD9945602265CF3363D0D928B0B452C3E32)
3360 piece(s) conforme(s), 0 differente(s)
```

Son code de retour vaut 0 si tout est conforme, 1 sinon.

```
# verifier-consigne.ps1 – checks the seal and every exhibit of a WAC collection
# (French output messages.) Usage: powershell -ExecutionPolicy Bypass -File verifier-
#   consigne.ps1 -Sortie E:\output
# Exit code: 0 if everything matches, 1 otherwise.

param([string]$Sortie = '.\output')

# 1. The seal: the manifest's fingerprint must be the one recorded beside it.
$annonce = ((Get-Content -Raw "$Sortie\exhibits\MANIFEST.sha256") -split '\s+')[0]
$reel    = (Get-FileHash -Algorithm SHA256 "$Sortie\exhibits\MANIFEST.json").Hash
if ($annonce -ne $reel) { Write-Output "SCEAU NON CONFORME : manifeste modifié"; exit 1 }
```

```
Write-Output "Sceau conforme ($reel)"

# 2. Every exhibit: its SHA-256 must be the one in the manifest.
$m = Get-Content -Raw -Encoding UTF8 "$Sortie\exhibits\MANIFEST.json" | ConvertFrom-Json
$ok = 0; $ko = 0; $fingerprintOnly = 0
foreach ($p in ($m.Items | Where-Object { $_.Result -eq 'OK' })) {
    # An authenticated binary that was not copied (--collect --binary): no file.
    if ($p.ContentStored -eq $false) { $fingerprintOnly++; continue }
    $f = Join-Path $Sortie $p.ExhibitPath
    $h = (Get-FileHash -Algorithm SHA256 -LiteralPath $f -ErrorAction SilentlyContinue).
    Hash
    if ($h -eq $p.SHA256) { $ok++ } else { $ko++; Write-Output "DIFFERENTE : $($p.
    ExhibitPath)" }
}
Write-Output "$ok piece(s) conforme(s), $ko differente(s)"
Write-Output "$fingerprintOnly binaire(s) authentifie(s), empreinte seule (pas de copie a
verifier)"
if ($ko) { exit 1 }
```

6.4 Le journal d'investigation

investigation.json retrace la collecte : outil et ligne de commande, machine et fuseaux horaires, opérateur, début, fin et durée, puis la liste **ordonnée** des opérations. Pour chacune :

Seq, TimestampUtc, TimestampLocal
rang et instant;

Operation, Target
ce qui a été fait, et sur quoi;

Result
l'issue;

Footprint
la trace que cette opération est censée laisser sur la machine examinée.

Ce journal permet de confronter, collecte par collecte, les traces attendues à celles effectivement observées. Il signale aussi un écart entre le fuseau horaire du suspect et celui de la machine de collecte.

6.5 Les fichiers d'artefacts

Un fichier par artefact. Les champs décrits sont ceux émis; un champ sans valeur n'est pas émis (voir chapitre 7).

6.5.1 Système et comptes

OperatingSystem.json

nom et domaine de la machine, édition et version de Windows, date d'installation, heure courante, **heure de démarrage**, durée d'activité, fuseau horaire. `BootTimeSource` dit d'où vient l'heure de démarrage (noyau, ou estimation de repli); `ClockAdjustedSinceBootMs` donne le cumul des corrections d'horloge depuis le démarrage — quelques secondes sont un recalage ordinaire, un grand écart signale une horloge modifiée.

users.json

comptes locaux, lus dans la ruche SAM : SID et RID, état, drapeaux, nombre de connexions et d'échecs, dates de dernière connexion, de dernier échec, de changement de mot de passe et de modification du compte, profil.

Sessions.json

sessions ouvertes au moment de la collecte : utilisateur, type d'ouverture, paquet d'authentification, heure de début.

processes.json

processus en cours : nom, identifiants (et parent), propriétaire, session, modules chargés, et, avec `--binary`, empreintes de l'exécutable.

services.json

services et pilotes, configuration lue dans la ruche : type, démarrage, compte, binaire et DLL hébergée, commande en cas d'échec, dépendances, dernière écriture de la clé; état courant; avec `--binary`, empreintes du binaire et de la DLL.

ScheduledTasks.json

tâches planifiées, lues dans leurs définitions XML : auteur, compte d'exécution, état, dernière exécution et son résultat, déclencheurs et actions (avec `--binary`, empreintes de la commande).

6.5.2 Exécution de programmes

prefetchs.json

fichiers Prefetch : programme, nombre et dates d'exécution, volumes, et liste des fichiers chargés avec leur référence \$MFT (et leurs empreintes avec `--binary`).

amcache_application_files.json, amcache_applications.json

inventaire Amcache des exécutables et applications : chemin, éditeur, version, dates.

shimcache.json

cache de compatibilité : chemin et date de modification du fichier. Une entrée prouve que le binaire était présent, pas qu'il a été exécuté.

bams.json

dernière exécution par programme et par utilisateur (Background Activity Moderator).

userassists.json

programmes lancés depuis l'interface : compteur, temps de focus, dernière exécution.

muicache.json

noms d'affichage des programmes exécutés.

run.json

programmes lancés au démarrage ou à l'ouverture de session (clés Run), avec la dernière écriture de la clé.

6.5.3 Fichiers et navigation

recentdocs.json

raccourcis de documents récents : cible, horodatages du raccourci et de la cible, volume (type, numéro de série, nom), chemin réseau, liste d'éléments du shell.

jumplistAutomaticDestinations.json, jumplistCustomDestinations.json

listes de sauts par application, avec les raccourcis qu'elles contiennent; pour les listes automatiques, chaque raccourci est accompagné de son entrée DestList (dernier accès, nom de la machine, identifiants de suivi, épinglage).

shellbags.json

dossiers parcourus dans l'Explorateur, arborescence reconstituée.

mrus.json, mruApps.json

listes de fichiers et d'applications récemment utilisés.

6.5.4 Périphériques

Usbstor.json

périphériques de stockage USB connus du système : Vendor, Product, Revision et Type, tirés de DeviceId; SerialNumber, tiré de InstanceId — absent quand l'identifiant a été fabriqué par Windows (deuxième caractère « & »), le périphérique n'en déclarant aucun; dates de première et de dernière insertion.

mounted_device.json

correspondance entre lettres de lecteur et périphériques. Drive nomme la lettre ou le volume; Type dit la forme de la valeur : GPT partition (PartitionGuid), MBR partition (DiskSignature et PartitionOffset, en octets), Device path (Device, chemin du périphérique, avec le numéro de série d'une clé USB) ou Unknown (Data, les octets en hexadécimal).

6.5.5 Journaux d'événements (--events)

events.json contient un objet par événement :

EvtSystem*

la section système : fournisseur, identifiant, niveau, tâche, mots-clés, horodatage de création, numéro d'enregistrement, processus et fil, canal, machine, utilisateur;

EvtEventData

les données de l'événement, en liste de paires Name / Value;

EvtEventMessage

le message lisible, tel que l'Observateur d'événements l'afficherait, reconstitué à partir des ressources du fournisseur prélevées sur la machine;

EvtSourceLog

le fichier journal dont provient l'événement. Un même canal peut être porté par plusieurs fichiers (journal courant et archives) dont les numéros d'enregistrement se recouvrent.

Messages incomplets

Une marque %1, %2... restée dans un message signifie que l'événement ne porte pas la donnée attendue : elle est laissée visible pour que la phrase ne paraisse pas complète. Tous les fournisseurs ne livrent pas de ressources de messages : leurs événements n'ont alors pas de EvtEventMessage, mais leurs données restent complètes.

Lire les données

7.1 Horodatages

Chaque date est émise deux fois : X en heure locale et X_{UTC} en UTC. L'heure locale est celle du **suspect**, calculée avec le fuseau lu dans sa ruche SYSTEM — pas celle de la machine de collecte. Les dates portent la fraction de seconde quand la source la fournit, et seulement dans la précision de cette source : sept chiffres pour un FILETIME, trois pour une date à la milliseconde, aucun pour une date à la seconde (date FAT, précise à deux secondes, date lue en texte, temps Unix).

Chaque date porte le décalage en vigueur **à cette date**, heure d'été comprise : une date de janvier relevée en été à Paris est à +01:00, une date de juillet à +02:00. WAC applique les règles de la machine examinée année par année (clé `Dynamic DST` de la ruche `SOFTWARE`) : une date de 2005 aux États-Unis suit les règles de 2005. Pour une valeur que l'artefact enregistre en heure locale (date FAT, Amcache, BAM...), l'heure répétée à l'automne est lue comme sa première occurrence, et l'heure sautée au printemps avec le décalage d'avant le changement, comme le fait Windows.

7.2 Noms des comptes

Les champs qui nomment un compte (`SIDName`, `Owner`, `RunAs`) sont tirés des preuves seules, sans interroger le système ni le réseau : comptes et groupes locaux de la base SAM (dans la langue de la machine examinée), SID bien connus sous leur nom canonique (`SYSTEM`, `LOCAL SERVICE`...), SID de services (`NT SERVICE`...), et dossier de profil pour un compte de domaine. Un SID qu'aucune de ces sources ne nomme est publié sans nom : le SID reste la preuve, à rapprocher du domaine par l'analyste.

7.3 Noms des GUID

Les champs qui nomment un GUID (classe COM, dossier connu, gestionnaire d'une tâche) viennent d'abord d'une table de référence, puis des ruches de la machine examinée : ses classes (`SOFTWARE\Classes\CLSID`), ses dossiers connus (`FolderDescriptions`), et les classes de chaque utilisateur (`UsrClass.dat`). Un composant installé sur la machine y est donc nommé, avec le module qui le sert. Un GUID que rien ne nomme est publié sans nom.

7.4 Un champ absent n'est pas un champ vide

Une valeur sans source n'est pas émise du tout. Une clé vide se lirait comme une lecture ratée, et ne se distinguerait pas de « la ruche ne contient pas cette valeur ». Ce qui n'a pas pu être lu est consigné dans `investigation.json`.

7.5 Artefact non collecté

Quand un artefact entier n'a pas pu être lu, son fichier le dit explicitement :

```
{
  "Artifact": "USBSTOR (registre)",
  "CollectionStatus": "NotCollected",
  "Error": "0x02 Le fichier spécifié est introuvable.",
  "Note": "La lecture de cet artefact a échoué : l'absence de données
          ci-dessus ne signifie PAS qu'aucune trace n'existe sur le système."
}
```

Attention

Un fichier d'artefact vide et un fichier « NotCollected » ne disent pas la même chose. Le premier indique qu'aucune entrée n'a été trouvée; le second, que la source n'a pas pu être lue.

7.6 Données non décodées

Un élément que WAC ne sait pas décoder (élément du shell inconnu, bloc d'extension non reconnu) est accompagné de ses octets bruts en hexadécimal, pour qu'un analyste puisse le décoder plus tard. Avec `--dump`, la valeur brute des shellbags et des raccourcis est ajoutée systématiquement.

7.7 Chemins

Les chemins et valeurs sont restitués **tels qu'ils figurent sur le disque**, sans transformation : l'échappement n'intervient qu'à l'écriture du JSON.

Traces laissées sur la machine examinée

À lire avant d'employer WAC sur une affaire. Ce chapitre énumère ce que WAC fait à la machine, opération par opération, y compris ce qu'il ne peut pas éviter.

8.1 Ce que WAC fait encore

Opération	Trace
Lecture directe du volume	Un accès par volume effectivement lu (en général un seul). Aucun fichier ouvert, donc aucune date d'accès modifiée. Si l'audit d'accès aux objets est activé, l'ouverture du volume peut être journalisée (Security 4656/4663).
Écriture des résultats	Sur le support de collecte uniquement. Rien n'est écrit sur le disque examiné.
Rejeu des journaux de ruche	Sur la copie de travail uniquement, avec journal d'annulation.
État des services	Une requête en lecture au gestionnaire de services. Aucun service n'est ouvert ni modifié.
Processus	Un instantané du noyau ; aucun processus n'est ouvert. Relevé des propriétaires : une requête au service Terminal Services.
Sessions	Une requête en lecture à LSASS.
Heure de démarrage	Une requête en mémoire au noyau.
Journaux d'événements (- -events)	Lus par le même accès direct au volume : le service de journalisation n'est pas sollicité.
Fichiers cités (- -binary)	Lus par le même accès direct. Aucun fichier ouvert.
Vérification d'authenticité (- -binary)	Catalogues lus par le même accès direct ; vérification en mémoire. Aucun service sollicité, aucun accès au magasin de certificats, aucun accès réseau.

8.2 Ce que WAC ne fait plus

Les versions antérieures créaient un cliché instantané (VSS), passaient par COM et WMI, interrogeaient le planificateur de tâches et le service de journalisation, ouvraient chaque processus et chaque service, lisaient la liste des profils dans le registre vivant et ouvraient chaque fichier cité pour en calculer l'empreinte. Toutes ces opérations, qui laissaient des entrées dans les journaux ou modifiaient des dates d'accès, ont été supprimées.

8.3 Ce qu'aucun outil ne peut éviter

Ces traces sont listées pour que l'analyste reconnaisse l'empreinte de WAC au lieu de la prendre pour l'activité étudiée :

- **lancer WAC.exe est une exécution** : elle produit un fichier Prefetch pour WAC.exe, une entrée Amcache et, si l'audit de création de processus est actif, un événement Security 4688. Attendez-vous à retrouver WAC dans les artefacts qu'il collecte;
- **brancher la clé USB** l'inscrit dans USBSTOR, MountedDevices et les journaux associés;
- **ouvrir une session** pour lancer l'outil crée une session et ses entrées de journal;
- la lecture de plusieurs gigaoctets **vide le cache du système de fichiers**, ce qui modifie l'état de performance de la machine (pas le contenu de son disque).

Limites connues

Volumes non NTFS

Un fichier situé sur un CD-ROM ou une clé FAT n'est pas lu : il est signalé comme non lu.

Variables propres à un utilisateur

Un chemin exprimé avec %APPDATA%, %LOCALAPPDATA% ou %USERPROFILE% (dans une tâche planifiée, par exemple) n'est pas résolu : le compte concerné n'est pas connu à cet endroit, et deviner donnerait l'empreinte d'un autre fichier.

Exécutable supprimé

Un processus dont l'exécutable a été effacé du disque n'a pas d'empreinte : il ne reste que la mémoire, hors du périmètre de WAC.

Messages d'événements

Environ un tiers des événements reçoivent un message lisible sur la machine de test ; les autres fournisseurs ne livrent pas de ressources exploitables. Les données, elles, sont toujours complètes.

Signés mais non authentifiés

Quelques sortes de fichiers réellement signés restent prélevées, dans le sens prudent : les applications du Microsoft Store (signées au niveau du paquet, et non fichier par fichier) et les scripts Windows Script Host signés seulement dans leur texte.

Dépannage

Message ou constat	Cause et remède
Échec de « Check administrator rights »	L'invite n'a pas été lancée en tant qu'administrateur. Relancez-la avec les droits d'administrateur.
Échec de « Check OS >= Windows 10 »	Système antérieur à Windows 10 : non pris en charge.
Échec de « Checking the collection medium », répertoire non vide	Le dossier de sortie contient une collecte antérieure. Indiquez un dossier neuf avec --output.
Échec de « Checking the collection medium », place insuffisante	Le support est trop petit pour les options choisies (section 3.2). Utilisez un support plus grand ou retirez --binary.
Un fichier d'artefact porte "CollectionStatus": "NotCollected"	La source n'a pas pu être lue ; le motif est dans Error. Les autres artefacts ne sont pas affectés.
Des pièces en échec au manifeste	Fichiers cités absents du disque (logiciel désinstallé, profil de service sans ruche), volume non NTFS... Le motif est dans Result.
Le journal indique des binaires « hachés sans être copiés »	La place a manqué pendant le prélèvement : les empreintes sont complètes, les copies non.
Besoin de comprendre un échec de lecture	Relancez avec --loglevel=2 (et, pour la lecture NTFS, --debug) et consultez WAC.exe.log.

Glossaire

Artefact

Trace laissée par l'activité du système ou d'un utilisateur, et exploitable en investigation.

Consigne

Répertoire des copies brutes, scellé, jamais réécrit.

Empreinte

Valeur calculée sur le contenu d'un fichier (MD5, SHA-1, SHA-256) : deux contenus différents ont des empreintes différentes.

Journal de transaction

Fichier .LOG1/.LOG2 contenant les modifications récentes d'une ruche, pas encore écrites dans celle-ci.

Manifeste

Fichier qui identifie chaque pièce de la consigne.

\$MFT

Table des fichiers d'un volume NTFS.

Ruche

Fichier constituant une partie de la base de registre (SYSTEM, SOFTWARE, ntuser.dat...).

Sceau

Empreinte du manifeste, conservée à part : elle révèle toute retouche du manifeste.

Travail

Répertoire des copies de travail, sur lesquelles portent l'analyse et les éventuelles modifications.

WOF / Compact OS

Mode de stockage compressé des fichiers système de Windows 10 et 11.